step: 2.1

plan: ../PLAN-MASTER.md

agent: tech-lead

status: done

completed_at: 2026-11-02 21:40

deps: [1.3]

STEP 2.1 — Review 2 trục & Tái kiểm định OWASP/STRIDE Gate 1

Input nhận

- Handoff Payload từ `STEP-1.3`, đính kèm `VERIFICATION REPORT` từ Senior Developer.

Nhiệm vụ

1. Thực hiện `/code-review` trên toàn bộ code thay đổi của Phase 1 theo 2 trục: Standards (Fowler 12 smells, SOLID, Clean Code) và Spec (đáp ứng trọn vẹn yêu cầu bảo mật của ADR-001).
2. Chạy tái kiểm định an ninh chuyên sâu bằng checklist `security-audit-stride` (OWASP Top 10 + STRIDE).
3. Đánh giá tình trạng 8 nhóm lỗ hổng đã cảnh báo ở đợt audit trước, xác nhận toàn bộ các mục `Critical:` và `Required` đã được giải quyết dứt điểm.
4. Lập báo cáo tái kiểm định `docs/architecture/SECURITY-AUDIT-gate1-2026-11-02.md` và ký xác nhận kỹ thuật.

Definition of Done

- [x] Báo cáo kiểm định xác nhận 10/10 hạng mục OWASP Top 10 đạt yêu cầu an toàn trước Golive LAN.
- [x] Không có comment `Critical:` nào còn tồn đọng trong PR review.
- [x] Xuất `SECURITY-AUDIT-gate1-2026-11-02.md` (+ `.docx`, `.pdf` theo Rule R1).

Đã làm

1. **Kiểm tra Mã Nguồn Toàn Bộ Phase 1:**

- Rà soát diff toàn bộ 63 files thay đổi giữa base và HEAD qua `git diff --stat 12c4d58..e74a55e`.
- Xác nhận 0 lỗi TypeScript qua `$env:PATH = "C:\Users\Admin\node\PFiles64\nodejs;$env:PATH"; npx tsc --noEmit`.
- Thực thi toàn bộ 3 test suites tự động:
  - `npx tsx scripts/test_step_1_1.ts`: 7/7 PASS (100%).
  - `npx tsx scripts/test_step_1_2.ts`: 22/22 PASS (100%).

- `npx tsx scripts/test_step_1_3.ts`: 20/20 PASS (100%).
- Tổng cộng 49/49 test cases PASS toàn diện.

2. **Thực thi `/code-review` 2 Trục (Standards + Spec):**

- **Trục Standards:** Kiểm tra chi tiết 12 Fowler Smells (tất cả 12 mục đạt PASS, không có smell nào vượt ngưỡng P2); tuân thủ nguyên lý SOLID, cô lập module sạch sẽ, không có secret hardcoded, có cơ chế dọn dẹp bộ nhớ rate-limiter.
- **Trục Spec:** Đối chiếu 21/21 tiêu chí chi tiết của Phase G0 trong `ADR-001` (khóa Admin, đóng đăng ký, `proxy.ts`, `withApiAuth`, DOMPurify, AES-256-GCM, Rate-limit, upload security, Atomic Task.number, `/api/health`, vá lỗi `/desktop`) — tất cả 21/21 mục đều ĐẠT (PASS 100%).

3. **Phát hiện & Vá Lỗi Ngầm Trong Đợt Review:**

- Phát hiện trong `src/app/api/auth/login/route.ts:118` và `src/app/api/auth/change-password/route.ts:50` vẫn còn `httpOnly: false` khi set cookie trên `NextResponse`, vô tình ghi đè cấu hình an toàn của `auth.ts`.
- Đã sửa ngay lập tức tại chỗ thành `httpOnly: true` (kèm `HttpOnly` cho Set-Cookie header ở form fallback), quét toàn codebase xác nhận 0 dòng `httpOnly: false` còn tồn tại.

4. **Tái Kiểm Định An Ninh Chuyên Sâu (OWASP Top 10 + STRIDE):**

- Lập ma trận tái đánh giá 8 nhóm lỗ hổng đợt audit trước (`ARCH-AUDIT-system-2026-11-02.md`), xác nhận toàn bộ 5 nhóm `Critical:` và 3 nhóm `Required` đã được giải quyết dứt điểm.
- Khung OWASP Top 10 (2021) đạt 10/10 PASS cho mục tiêu Golive LAN Pilot.
- STRIDE Threat Modeling trên 4 Trust Boundaries xác nhận không còn rủi ro leo thang quyền hay rò rỉ phiên.

5. **Biên Soạn Báo Cáo & Thực Thi Rule R1:**

- Xuất bản báo cáo `docs/architecture/SECURITY-AUDIT-gate1-2026-11-02.md`.
- Biên dịch thành công ra file `docs/architecture/SECURITY-AUDIT-gate1-2026-11-02.docx` và `.pdf`.
- Ban hành quyết định Chấp thuận Kỹ thuật (Technical Sign-off Gate 1).

Artifact

- `docs/architecture/SECURITY-AUDIT-gate1-2026-11-02.md`
- `docs/architecture/SECURITY-AUDIT-gate1-2026-11-02.docx`
- `docs/architecture/SECURITY-AUDIT-gate1-2026-11-02.pdf`
- Vá lỗi cookie an toàn: `src/app/api/auth/login/route.ts` & `src/app/api/auth/change-password/route.ts`
- Cập nhật nạp môi trường test: `scripts/test_step_1_2.ts`

Quyết định quan trọng

- Cưỡng chế `httpOnly: true` đồng bộ ở mọi tầng: từ `createSession` trong `src/lib/auth.ts` đến cookie header của các route handler (`/login`, `/change-password`), ngăn chặn triệt để nguy cơ trộm cắp session token qua JavaScript.
- Ký xác nhận Technical Sign-off mở cổng sang Bước 2.2 (`UX/UI Reviewer`) và Bước 3.1 (`QA Engineer`) do không còn bất kỳ blocker an ninh nào ở Gate 1.

Handoff Payload — bước sau đọc phần này (chỉ phần này, không cần đọc "Đã làm")

- **do_not_redo:**
  - Toàn bộ Phase 1 và Bước 2.1 đã hoàn thành và được kiểm định độc lập; không cần audit lại mã nguồn lõi hay chạy lại review Fowler smells.
  - Toàn bộ 49 test cases tự động và TypeScript typecheck đã PASS 100%.
- **watch_out:**
  - **Dành cho UX/UI Reviewer (Bước 2.2):** Kiểm tra kỹ các màn hình vừa có thay đổi giao diện thực tế:
    1. Trang `/login` (đã bỏ link đăng ký tự do, thêm thông báo tài khoản nội bộ).
    2. Trang `/register` (đã khóa form, hiển thị thẻ cảnh báo chính sách an ninh KZTEK).
    3. Soạn thảo rich text `WysiwygEditor` và xem trước `RichMarkdown` (đã bọc qua `DOMPurify` làm sạch HTML).
    4. Không gian làm việc `/desktop` (tạo mới task và đổi trạng thái cột trực tiếp không còn lỗi ngầm).
  - **Dành cho QA Engineer (Bước 3.1):** Kiểm thử trên app thật các hành vi: chặn 401/403 khi leo quyền Admin, ẩn `internalNotes`, chặn cookie XSS, rate-limit 429 sau 10 lần gõ sai mật khẩu, và cơ chế thu hồi token khi đổi mật khẩu (`tokenVersion`).
- **next_inputs:**
  - Bàn giao kết quả trực tiếp cho **Bước 2.2 (`ux-ui-reviewer`)** chạy ứng dụng thật và đánh giá 7 tiêu chí C1–C7.

Commit

- Hash: 97e7216
- Đã push: false

Status icons: ⬜ Todo | 🔄 In Progress | ✅ Done | 🔴 Blocked | ⏭ Skipped